

Risk assessment: NV-2 water level probe, version 1.0

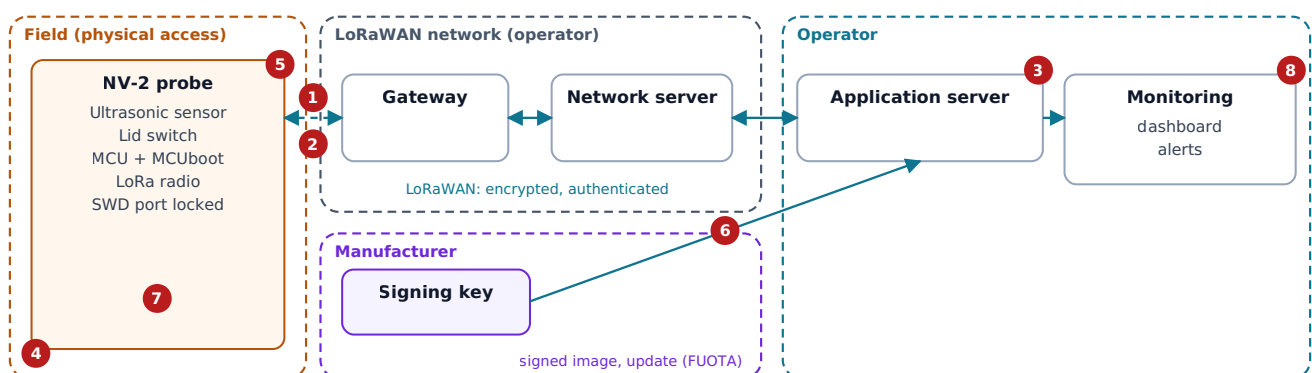
Fictional example, written for the "CRA & Dev" series to illustrate Article 13 of the Cyber Resilience Act. The product, the choices and the ratings are examples: they do not replace the analysis of your own product.

1. Context

Item	Content
Intended purpose	Measure the water level of a public tank or reservoir, derive the volume, send it every hour over LoRaWAN, and raise an alert at once below a low threshold or above a high one. The local authority uses it to plan refills and to monitor its firefighting water reserves.
Reasonably foreseeable use	Sole monitoring of a firefighting reserve, without regular visual checks; leak detection; data shared with the emergency services.
Conditions of use	Outdoors, on remote and often unattended sites. Battery powered. Public LoRaWAN network.
Assets to protect	Integrity and availability of the levels and alerts, on which the safety of people depends for firefighting reserves; alert thresholds; firmware integrity; LoRaWAN keys (a root key unique to each device).
Data processed	Level, computed volume, temperature, battery voltage, lid state. No personal data.
Expected time in use	10 years. Support period: 10 years.
Interfaces	LoRaWAN radio (readings, alerts, threshold configuration, updates); SWD debug port, locked in production; lid switch.

2. Diagram

The numbers refer to the risks in the next table.



3. Risks

Likelihood (L) and impact (I): low, medium, high.

#	Threat: who, through what	L	I	Decision	Measure or justification
1	A forged or replayed frame makes an empty reserve look full	low	high	reduce	Authenticated frames and frame counters; OTAA activation only: each session has its own keys, a frame from a past session is rejected; the platform rejects physically impossible level changes (point 2 (f)).
2	The probe goes silent (jamming, flat battery, destroyed probe) and a drop goes unnoticed	medium	high	reduce	A heartbeat every hour; a low-battery alert a month ahead. Assumption documented in the user guide: the platform must alert after two missed messages (point 2 (h)).
3	Alert thresholds are changed remotely to silence the alerts	low	high	reduce	Configuration accepted only if authenticated; bounded thresholds; each change is reported to the platform and logged (point 2 (d), (l)).
4	On site, someone opens the probe, moves it or blocks the sensor	medium	medium	reduce	The lid switch sends an alert; a reading outside the possible range is flagged (point 2 (d)).
5	The root key is extracted from a stolen probe	medium	low	reduce	One key per device: a theft compromises one probe only. SWD port locked (point 2 (d), (j)).
6	Malicious firmware is pushed through the radio update	low	high	reduce	Image signed by the manufacturer, verified by MCUboot before installation; rollback to an older version forbidden (point 2 (c), (f)).
7	A known vulnerability affects a dependency (RTOS, LoRaWAN stack)	high	high	reduce	SBOM for each release, continuous monitoring; fix released without delay, separate from functional changes (Part II, points 1 and 2).
8	The local authority's server is compromised and shows false values	medium	high	out of scope, documented	Outside the product. The user guide recommends two-factor authenticated access and alerts sent through a second channel.

4. Annex I, Part I, point 2

Point	Applicable?	Implementation, or justification
(a) No known exploitable vulnerability	Yes	SBOM analysed before each release; no known exploitable vulnerability is shipped.
(b) Secure by default, reset to original state	Yes	No shared default secret; cautious factory thresholds. An internal button restores the factory configuration, and the probe reports it.
(c) Security updates	Yes	Signed radio updates, installed automatically by default; the operator can postpone them.
(d) Protection from unauthorised access	Yes	No local interface; SWD locked; only authenticated commands are accepted; lid opening reported.
(e) Confidentiality	Yes, low stakes	Payload encrypted by LoRaWAN; no personal data.
(f) Integrity	Yes, high stakes	Authenticated frames, frame counters, OTAA activation; signed firmware; bounded thresholds.
(g) Data minimisation	Yes	Only the quantities needed for monitoring are sent.

Point	Applicable?	Implementation, or justification
(h) Availability of essential functions	Yes, high stakes	Thresholds are evaluated in the probe, without waiting for a command; hourly heartbeat; watchdog; low-battery alert.
(i) No impact on other networks	Yes	Radio duty cycle respected; connection retries spaced out, with some randomness.
(j) Limited attack surface	Yes	A single external interface, the radio; SWD locked.
(k) Exploitation mitigation	Yes	Compiler and RTOS hardening (stack canaries, MPU memory protection).
(l) Logging and monitoring	Yes	Threshold changes, lid openings, restarts and updates are sent to the platform. The opt-out exists, as the text requires; it is itself reported, and the user guide advises against it for a firefighting reserve.
(m) Removal of data and settings	Yes	Factory reset erases the session, thresholds, configuration and local history. The root key is kept: it is the device's identity, not user data.

5. Annex I, Part I, point 1, and Part II

- **Target cybersecurity level: high.** An empty firefighting reserve that looks full puts the safety of people at stake, which Article 13(2) requires to be taken into account. Integrity and availability of the alerts come first.
- **Vulnerability handling:** a CycloneDX SBOM for each release, continuous monitoring of dependencies, a published contact address with a disclosure policy, fixes delivered without delay by radio update, published security advisories.

6. History

Date	Version	Change
2026-10-06	1.0	First assessment.